

Trivy - Scanner de Vulnerabilidades Universal

Segurança Shift-Left para Contêineres, IaC e Código

Alunos: Gabriel Teles e Lucas Vieira

Data: 28/11/2025

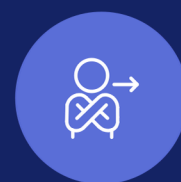


O que é Trivy?



Scanner de Código Aberto

Rápido e abrangente, projetado para detectar vulnerabilidades e configurações incorretas em diversos alvos.



SAST e SCA

Atua na Análise de Segurança de Aplicações Estática (SAST) e Análise de Composição de Software (SCA).



Integrado ao CI/CD

Ideal para pipelines de Integração Contínua / Entrega Contínua, prevenindo vulnerabilidades antes do deploy.

O Trivy se posiciona como uma ferramenta essencial na "pirâmide de testes" de segurança, focado em identificar falhas no início do ciclo de desenvolvimento.

Funcionalidades: Alvos Abrangentes do Trivy

O Trivy não se limita a imagens de contêineres, ele oferece uma cobertura ampla para garantir a segurança em diversas frentes.



Imagens de Contêiner

Varre vulnerabilidades em pacotes de OS e dependências de linguagem em suas imagens Docker e OCI.



Sistemas de Arquivos/Git Repos

Analisa repositórios de código e sistemas de arquivos locais em busca de vulnerabilidades e configurações incorretas.



IaC (Infrastructure as Code)

Detecta configurações de segurança falhas em arquivos Terraform, CloudFormation, Ansible e outros.



Kubernetes Configs

Valida arquivos de configuração do Kubernetes para garantir que estejam em conformidade com as melhores práticas de segurança.



Segredos (Hardcoded Secrets)

Identifica segredos codificados (chaves API, senhas) em seu código e configurações, prevenindo exposições acidentais.

Por que a Segurança de Imagens é CRÍTICA?

A imagem base de um contêiner é a fundação de toda a sua aplicação. Ela contém o sistema operacional, bibliotecas e dependências de linguagem.

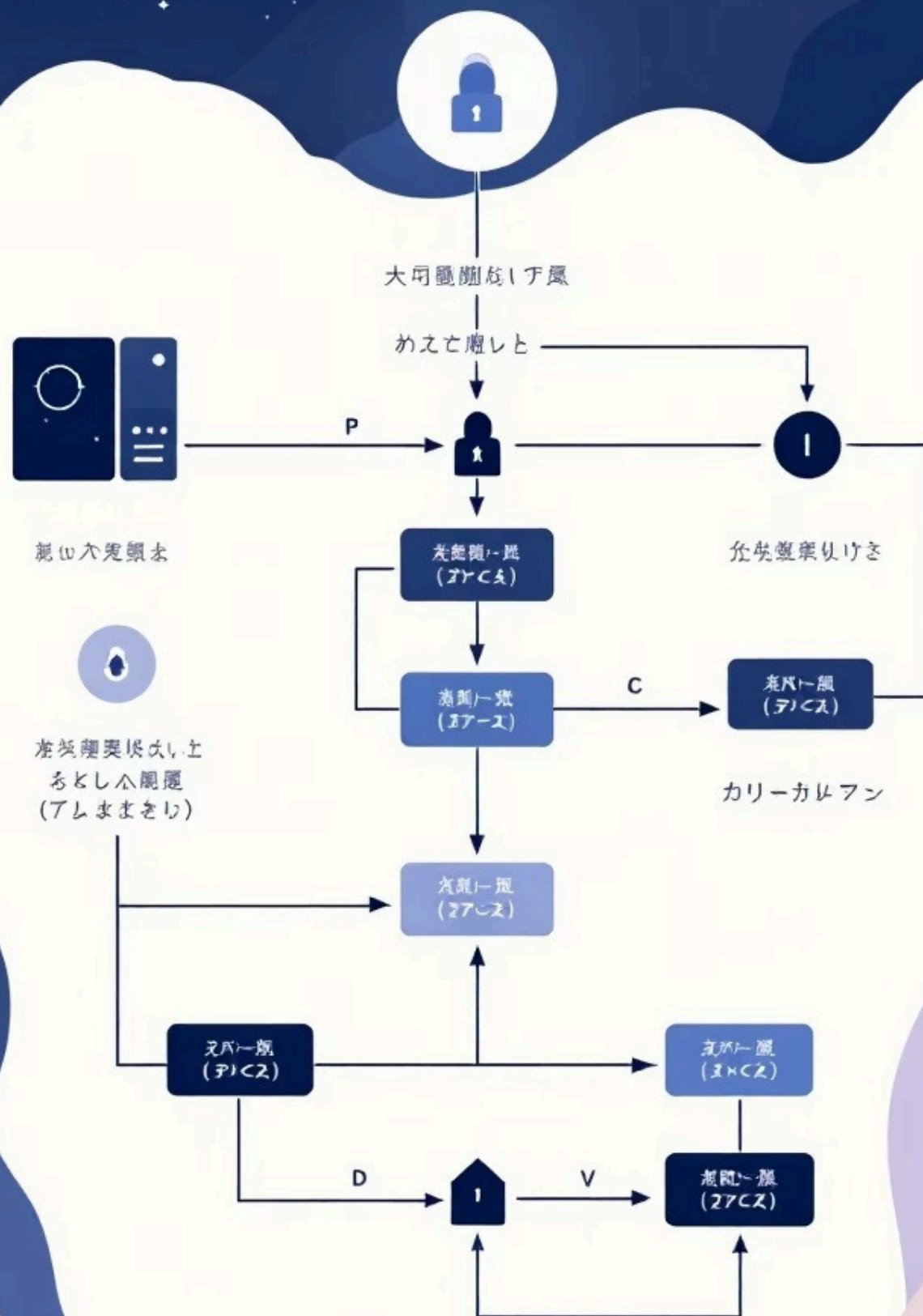
- **Efeito Dominó:** Uma vulnerabilidade na imagem base pode comprometer toda a cadeia de supply chain da sua aplicação.
- **Exposição Ampla:** Qualquer falha aqui expõe a aplicação a ataques, mesmo que o código da sua aplicação seja seguro.
- **Detecção de CVEs:** O Trivy se especializa na detecção de Common Vulnerabilities and Exposures (CVEs) em pacotes e bibliotecas.

❏ O princípio "Shift-Left" enfatiza a importância de mover a segurança para as fases iniciais do ciclo de desenvolvimento, identificando e corrigindo vulnerabilidades o mais cedo possível.



Como o Trivy Funciona: Por Trás da Varredura

Entenda o processo técnico que o Trivy utiliza para identificar e relatar vulnerabilidades



1. Varredura da Imagem

O Trivy analisa o manifesto da imagem e a lista de todos os pacotes de OS e dependências de linguagem instalados.

2. Referência a Bancos de Dados

Compara a lista de pacotes detectados com bases de dados de vulnerabilidade conhecidas (NVD, advisories de distribuidores de OS, etc.).

3. Output e Remediação

Fornece um relatório detalhado das vulnerabilidades, incluindo a crucial **"Fixed Version"** para orientar a remediação eficaz.

DEMONSTRAÇÃO: Trivy na Prática

1

Caso de Uso 1:

Imagem Limpa (SUCESSO)

`alpine:latest` - Espera-se poucas ou nenhuma vulnerabilidade devido à sua natureza minimalista e atualizada.



2

Caso de Uso 2:

Imagem Vulnerável (FALHA)

`nginx:1.21.6-alpine` - Esta versão específica contém vulnerabilidades conhecidas que o Trivy deverá identificar.



Trivy vs. Concorrentes: Análise Comparativa

Como o Trivy se posiciona em relação a outras ferramentas populares de varredura de vulnerabilidades?

Ferramenta	Trivy	Grype	Snyk
Abrangência	Contêineres, IaC, Segredos, FS	Contêineres, IaC, FS	Contêineres, Código, IaC
Velocidade	Muito Rápido (binário único)	Rápido	Moderado
Licença	Open Source (Apache 2.0)	Open Source (Apache 2.0)	Comercial (com plano gratuito)
Foco Principal	Simplicidade e CI/CD	Detecção de SBOM	Cobertura end-to-end

Menção honrosa: Clair e OWASP Dependency-Check

Trivy: Vantagens e Desvantagens

Pontos Positivos (Vantagens)

→ Simplicidade Imbatível

Binário único, fácil de instalar e integrar em qualquer ambiente.

→ Velocidade para CI/CD

Execuções rápidas que não atrasam seus pipelines de entrega contínua.

→ Universalidade de Alvos

Varre não apenas contêineres, mas também IaC, repositórios Git, segredos, etc.

→ Relatórios Detalhados

Fornece informações claras sobre vulnerabilidades e versões corrigidas.

Pontos Negativos (Desvantagens)

→ Risco de Falsos Positivos

Pode reportar vulnerabilidades que não são exploráveis em seu contexto específico, exigindo baselines.

→ Dependência de Atualização do DB

A eficácia depende diretamente da atualização dos bancos de dados de vulnerabilidades.

→ Não cobre DAST/SAST de Código-Fonte

Não substitui scanners de código-fonte dinâmicos ou estáticos para a lógica da aplicação.

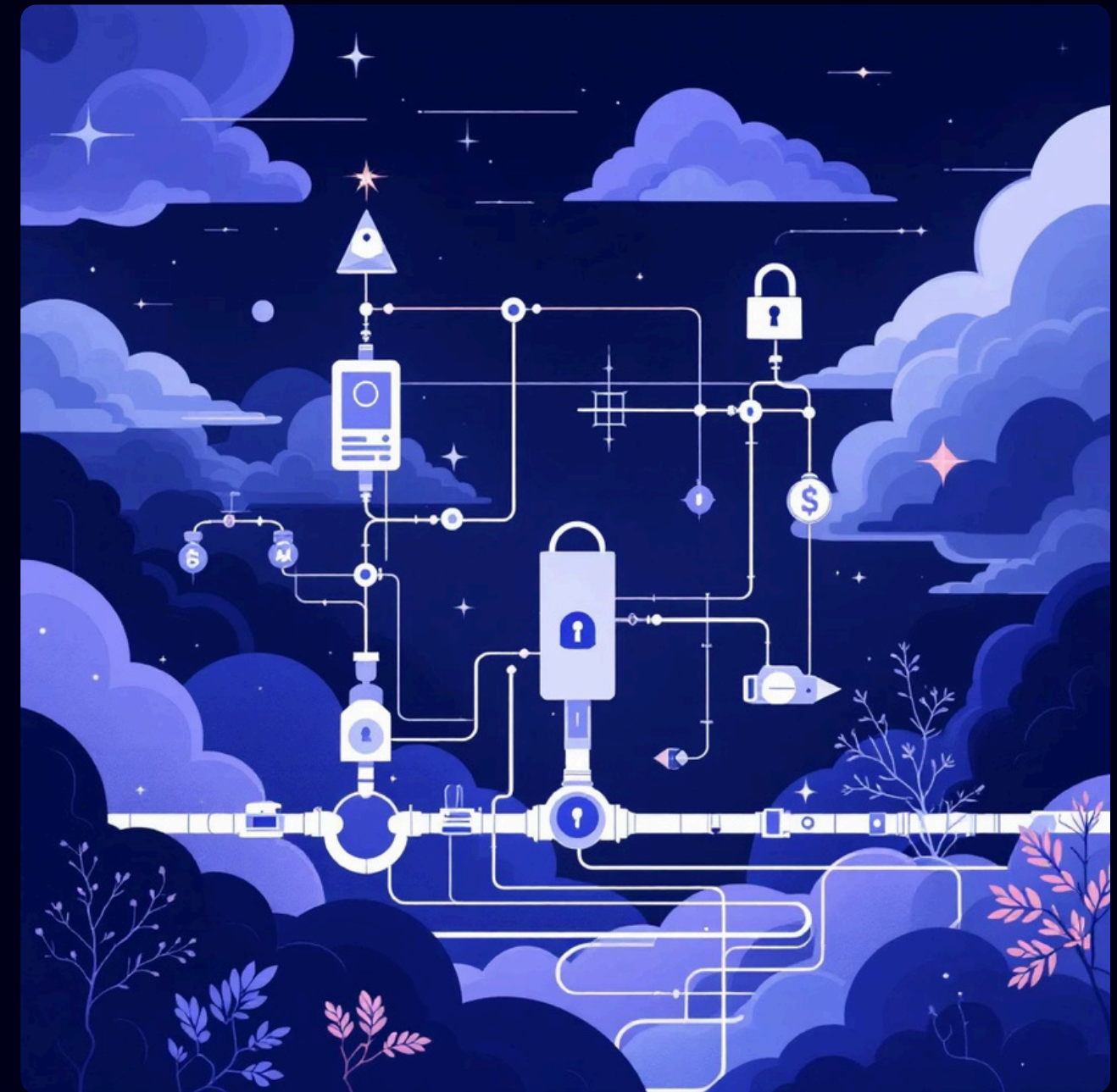
Avaliação Crítica e Recomendações

O Trivy é uma ferramenta poderosa, mas seu uso deve ser estratégico e complementar.

Quando Adotar o Trivy:

- Em pipelines DevSecOps que exigem varredura **rápida e automatizada**.
- Em projetos Cloud-Native que utilizam **contêineres extensivamente**.
- Para equipes que buscam uma solução **open source e de fácil integração**.
- Como primeira linha de defesa para o **Shift-Left Security**.

Quando Não Adotar (como única ferramenta): O Trivy é um excelente scanner, mas **não deve ser a única ferramenta de segurança**. Ele deve ser complementado com soluções de DAST (Dynamic Application Security Testing) e SAST de código-fonte para uma cobertura de segurança completa.



Exemplo de Uso do Trivy

1. Instalação

Adicione o Trivy ao seu ambiente de CI/CD (ex: `curl -sL https://raw.githubusercontent.com/aquasecurity/trivy/main/contrib/install.sh | sh -s -- -b /usr/local/bin`).

2. Varredura

Execute os comando

- `trivy image --severity HIGH,CRITICAL --format json --output $REPORT_CLEAN $TARGET_IMAGE_CLEAN`
- `trivy image --severity HIGH,CRITICAL --format json --output $REPORT_VULN $TARGET_IMAGE_VULN`

após a build da imagem.

3. Bloqueio

Se o `exit-code` for 1, a build falhará, impedindo que imagens vulneráveis cheguem à produção.

4. Relatório

Gere relatórios em diferentes formatos (JSON, HTML) para análise e auditoria.

